

Manual: Segurança da Informação

Princípios CID, Criptografia Simétrica e Assimétrica, Assinatura e Envelopamento Digital, Malwares (Virus, Worm, Ransomware), Firewalls, IDS/IPS e Normas ISO 27001/27002

CONCURSO: SEFAZ-BA 2026

Cargo: Auditor Fiscal (TI) & Agente de Tributos Estaduais (Geral)

Foco de Bancas: FGV e Cebraspe

Este material foi consolidado com base na bibliografia recomendada e no edital.

1. Principios Basicos da Seguranca da Informacao

A Seguranca da Informacao visa proteger a informacao contra ameacas para garantir a continuidade dos negocios e mitigar riscos. Baseia-se em tres principios classicos fundamentais (Mnemoneco: C.I.D.):

- **Confidencialidade:**
Garantia de que a informacao seja acessivel exclusivamente por pessoas autorizadas. Evita vazamentos e acessos indevidos.
- **Integridade:**
Garantia de que a informacao nao seja alterada de forma nao autorizada ou acidental ao longo do seu ciclo de vida. Assegura a precisao e completitude dos dados.
- **Disponibilidade:**
Garantia de que os usuarios autorizados tenham acesso a informacao e aos ativos correspondentes sempre que necessario.

Principios Estendidos

- **Autenticidade:**
Garantia de que a informacao e legitima e procede da fonte anunciada (identificacao correta do remetente).
- **Nao-repudio (ou Irretratabilidade):**
Impossibilidade de o emissor ou receptor negar a autoria de uma acao ou transacao realizada.

NAO-REPUDIO EM CONCURSOS

Para que ocorra o Nao-repudio, e obrigatoria a combinacao previa dos principios de Autenticidade (saber quem fez) e Integridade (garantir que nao foi modificado). Sem eles, a autoria pode ser contestada legalmente.

2. Criptografia Simetrica e Assimetrica

A criptografia é a ciência de cifrar (esconder) mensagens legíveis em formatos ilegíveis (texto cifrado) utilizando chaves matemáticas, garantindo a Confidencialidade da informação.

Criptografia Simetrica (Chave Unica)

Utiliza uma mesma chave secreta compartilhada para cifrar (bloquear) e decifrar (desbloquear) a mensagem:

- **Vantagens e Desvantagens:**

Muito rápida e ótima para grandes volumes de dados. Contudo, possui o problema de distribuição de chaves (como enviar a chave secreta ao destinatário de forma segura antes da mensagem?).

- **Algoritmos Principais:**

AES (Advanced Encryption Standard - atual padrão seguro), DES, 3DES, RC4, Blowfish.

Criptografia Assimetrica (Par de Chaves)

Utiliza um par de chaves matematicamente relacionadas: uma Chave Pública (divulgada a todos) e uma Chave Privada (mantida em segredo absoluto pelo dono):

- **Funcionamento Básico:**

Tudo o que é cifrado pela chave pública de uma pessoa só pode ser decifrado pela chave privada correspondente daquela mesma pessoa. E vice-versa.

- **Vantagens e Desvantagens:**

Resolve o problema de distribuição de chaves (basta publicar a chave pública). Contudo, é muito mais lenta e exige maior processamento computacional.

- **Algoritmos Principais:**

RSA, ECC (Criptografia de Curvas Elípticas), Diffie-Hellman.

QUEM CIFRA E QUEM DECIFRA?

Para garantir CONFIDENCIALIDADE: o remetente cifra a mensagem usando a Chave Pública do DESTINATÁRIO. Somente o destinatário conseguirá decifrar usando sua própria Chave Privada.

3. Assinatura Digital e Envelopamento

A combinação das chaves assimétricas permite alcançar diferentes objetivos de segurança de forma integrada.

Assinatura Digital (Autenticidade e Integridade)

Garante a autoria e a integridade de um documento eletrônico. O processo de geração é:

- **1. Cálculo do Hash:**

Aplica-se uma função de resumo (hash - ex: SHA-256) sobre o documento original, gerando uma 'impressão digital' única de tamanho fixo do arquivo.

- **2. Cifragem do Hash:**

O remetente cifra o hash obtido usando a sua própria Chave Privada. Esse hash cifrado é a assinatura digital anexada ao documento.

- **3. Validação pelo Destinatário:**

O destinatário decifra a assinatura digital usando a Chave Pública do REMETENTE (obtendo o hash original) e calcula de forma independente o hash do documento recebido. Se os dois hashes forem idênticos, o documento não sofreu alteração e a autoria é confirmada.

Envelopamento Digital (Digital Envelope)

Garante a confidencialidade no envio de arquivos grandes com velocidade, unindo o melhor das duas criptografias:

- **Processo:**

Cifra-se o documento grande com uma chave simétrica descartável rápida (chave de sessão). Em seguida, cifra-se essa chave simétrica usando a chave pública assimétrica do destinatário (formando o envelope). O destinatário abre o envelope com sua chave privada para obter a chave simétrica e decifrar o arquivo.

CERTIFICADOS DIGITAIS (ICP-BRASIL)

O certificado digital é a carteira de identidade eletrônica de um usuário, associando uma pessoa física ou jurídica ao seu par de chaves. É emitido por uma Autoridade Certificadora (AC) credenciada no padrão X.509 sob a infraestrutura da ICP-Brasil.

4. Malwares e Ameaças Digitais

Malware é qualquer software intencionalmente desenvolvido para causar danos, roubar informações ou obter acesso não autorizado a sistemas computacionais.

Tipos Principais de Malwares

- **Virus:**
Programa malicioso que se insere e infecta outros programas e arquivos hospedeiros. Exige a execução do programa infectado pelo usuário para se propagar.
- **Worm (Verme):**
Programa autônomo que se propaga de forma automática através da rede de computadores, explorando vulnerabilidades de sistemas. Diferente do vírus, não precisa de um arquivo hospedeiro ou ação do usuário para se espalhar, consumindo banda de rede.
- **Cavalo de Troia (Trojan):**
Disguise-se de um programa útil ou legítimo (ex: um jogo ou utilitário) para enganar o usuário e executar funções ocultas e danosas na retaguarda.
- **Ransomware:**
Criptografa os dados do sistema da vítima e exige o pagamento de um resgate (normalmente em criptomoedas) para fornecer a chave de decifração.
- **Spyware (Keylogger/Screenlogger):**
Software espião projetado para monitorar atividades. Keylogger captura as teclas digitadas (senhas). Screenlogger captura a tela ao redor dos cliques do mouse.
- **Rootkit:**
Conjunto de ferramentas projetado para ocultar a presença de malwares em baixo nível (sistema operacional), driblando a detecção de antivírus.

ENGENHARIA SOCIAL E PHISHING

A engenharia social manipula psicologicamente pessoas para obter informações confidenciais (senhas). O Phishing é a fraude eletrônica que utiliza e-mails ou sites falsos fingindo ser instituições confiáveis (bancos) para roubar credenciais.

5. Mecanismos de Defesa: Firewalls e IDS/IPS

Para defender a infraestrutura de rede, utilizam-se dispositivos e softwares que controlam o fluxo de dados e identificam intrusões.

Firewalls (Porta de Entrada da Rede)

Dispositivo de segurança que monitora e filtra o tráfego de rede de entrada e saída com base em regras de segurança previamente estabelecidas. Tipos principais:

- **Filtro de Pacotes (Stateless):**
Analisa os pacotes isoladamente (IP de origem/destino, porta e protocolo), sem guardar relação de estado das conexões.
- **Inspeção de Estado (Stateful):**
Mantém uma tabela de estado das conexões ativas, validando se o tráfego de retorno pertence a uma sessão de conexão legítima já aberta.
- **WAF (Web Application Firewall):**
Firewall especializado em filtrar e monitorar o tráfego HTTP/HTTPS direcionado a aplicações web, bloqueando ataques como SQL Injection e Cross-Site Scripting (XSS).

IDS vs. IPS

- **IDS (Intrusion Detection System):**
Sistema de detecção de intrusão. Monitora de forma passiva o tráfego de rede, identifica anomalias ou assinaturas de ataques e gera alertas para os administradores de rede. Não bloqueia o ataque de forma ativa.
- **IPS (Intrusion Prevention System):**
Sistema de prevenção de intrusão. Atua de forma ativa, posicionado diretamente no fluxo de dados (in-line). Ao detectar um ataque, bloqueia o tráfego malicioso imediatamente.

DETECÇÃO POR ASSINATURA VS ANOMALIA

1) *Deteção por Assinatura: compara o tráfego com uma lista de ataques conhecidos (eficiente, mas não detecta ataques de dia zero - zero-day).* 2) *Deteção por Anomalia: estabelece um perfil de comportamento normal da rede e gera alertas para qualquer desvio desse padrão (detecta novos ataques, mas gera muitos falsos positivos).*

6. Cópias de Segurança: Métodos de Backup

A realização de backups garante a Disponibilidade e a recuperação de dados em caso de sinistros, falhas de hardware ou ataques de ransomware.

Tipos de Backup e Funcionamento

- **Backup Completo (Full):**

Copia todos os dados selecionados para o dispositivo de armazenamento, resetando o bit de arquivo (archive bit). É o método mais demorado e que consome mais espaço, mas a restauração é a mais rápida (exige apenas 1 arquivo).

- **Backup Incremental:**

Copia apenas os arquivos que foram alterados ou criados desde o ÚLTIMO backup de qualquer tipo (Full ou Incremental). Reseta o bit de arquivo. É o método de gravação mais rápido e que consome menos espaço. Contudo, a restauração é a mais complexa (exige o último Full e TODOS os incrementais subsequentes na ordem correta).

- **Backup Diferencial:**

Copia apenas os arquivos que foram alterados ou criados desde o ÚLTIMO backup COMPLETO (Full). Não reseta o bit de arquivo. Ocupa espaço intermediário. A restauração exige apenas o último Full e o último backup diferencial realizado.

Regra de Backup 3-2-1

Recomendação clássica de boas práticas de segurança para evitar perda total de dados:

- **3 Cópias de Dados:**

Manter três cópias distintas dos dados (1 cópia de produção ativa e 2 cópias de backup).

- **2 Mídias Diferentes:**

Armazenar os backups em duas tecnologias ou mídias diferentes. Ex: 1 em disco externo e 1 em fita LTO.

- **1 Localização Offsite:**

Manter pelo menos uma cópia de backup fora da organização (offsite ou na nuvem).

O BIT DE ARQUIVO (ARCHIVE BIT)

O bit de arquivo indica se um arquivo foi alterado desde o último backup. O backup Completo e o Incremental limpam (desmarcam) esse bit. O backup Diferencial apenas lê o bit sem alterá-lo, fazendo com que a próxima execução diferencial copie novamente os mesmos dados já salvos.

7. Normas de Segurança: ISO 27001 e ISO 27002

As normas da família ISO/IEC 27000 estabelecem padrões internacionais reconhecidos para a Gestão de Segurança da Informação corporativa.

ISO/IEC 27001 (Requisitos do SGSI)

A norma ISO 27001 especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão da Segurança da Informação (SGSI).

- **Foco Organizacional:**

É uma norma de certificação. Foca no processo de gestão de riscos de segurança, governança, comprometimento da liderança e conformidade.

- **O Ciclo PDCA:**

Utiliza o ciclo Plan (Planejar), Do (Executar), Check (Verificar) e Act (Agir) para garantir a melhoria contínua do sistema de gestão de segurança da informação.

ISO/IEC 27002 (Código de Prática / Controles)

A norma ISO 27002 fornece um guia detalhado de boas práticas de controles de segurança da informação para apoiar a implementação do Anexo A da ISO 27001.

- **Foco Técnico:**

Não é uma norma de certificação corporativa. É um catálogo prático de diretrizes e controles de segurança divididos em categorias (Controles Organizacionais, de Pessoas, Físicos e Tecnológicos).

DIFERENÇA CRUCIAL DE NORMAS

A ISO 27001 diz O QUE deve ser feito para criar o sistema de gestão de segurança (requisitos formais). A ISO 27002 fornece as diretrizes detalhadas de COMO implementar e gerenciar os controles práticos no dia a dia da TI.

8. Políticas de Controle e Segurança de Redes

A implementação prática de segurança da informação envolve políticas de controle de acesso rigorosas e o uso de redes criptografadas.

Modelos de Controle de Acesso (Autenticação)

- **MFA (Autenticação Multifator):**
Exige o uso de dois ou mais fatores de autenticação baseados em categorias distintas para validar o login: 1) O que você sabe (senha, PIN); 2) O que você tem (token físico, smartphone, cartão); 3) O que você é (biometria, facial).
- **RBAC (Role-Based Access Control):**
Controle de acesso baseado em papéis ou perfis de usuário. As permissões são atribuídas aos papéis (ex: perfil Auditor, perfil Analista) e os usuários são associados a esses perfis, simplificando a gestão de acessos.

Segurança em Redes de Comunicação

- **VPN (Virtual Private Network):**
Cria um túnel criptografado seguro e privado através de uma rede pública (Internet), ligando de forma segura computadores remotos à rede interna da organização.
- **Protocolo SSL/TLS:**
Garante a segurança das comunicações na web (ex: protocolo HTTPS). Utiliza criptografia assimétrica para negociação de chaves e simétrica para transmissão de dados criptografados na sessão.

PRINCÍPIO DO MENOR PRIVILEGIO

Regra básica de segurança da informação: cada usuário ou processo deve ter acesso exclusivamente aos recursos e dados estritamente necessários para a realização de suas funções (RBAC). Evita danos acidentais ou deliberados.

9. As 10 Grandes Pegadinhas de Seguranca

Questoes de concursos de bancas como FGV e Cebraspe mapeiam armadilhas frequentes sobre Seguranca da Informacao:

- **1. Chave Privada nao assina para Confidencialidade:**

Cifrar com chave privada do remetente gera Assinatura Digital (garante Autenticidade e nao-repudio). Cifrar com chave publica do destinatario garante Confidencialidade (segredo).

- **2. Nao-repudio exige assinatura digital:**

O nao-repudio so e garantido se houver assinatura digital autenticada com chaves assimetricas. Criptografia simetrica simples nao garante nao-repudio (pois a chave e compartilhada).

- **3. Diferenca entre Worm e Virus:**

Worms nao precisam de arquivos hospedeiros para infectar e propagar; eles se espalham de forma automatica explorando redes. Os virus precisam de hospedeiros executados pelo usuario.

- **4. Trojan nao e auto-replicavel:**

Diferente de virus e worms, o Cavalo de Troia (Trojan) nao se multiplica ou infecta outros arquivos sozinho; ele depende de ser baixado e executado manualmente pelo usuario enganado.

- **5. Backup Incremental e o mais lento para restaurar:**

O backup incremental e o mais rapido para gravar, mas o mais demorado e arriscado para restaurar, pois exige a montagem do ultimo completo e de todos os incrementais na ordem exata.

- **6. Backup Diferencial nao reseta o bit de arquivo:**

O backup diferencial apenas copia arquivos modificados desde o ultimo Full. Como nao reseta o bit, backups diferenciais subsequentes acumulam e duplicam dados ja salvos.

- **7. IDS nao bloqueia ataques de rede:**

O IDS e passivo, apenas analisa e emite alertas. Quem age ativamente e bloqueia conexoes no fluxo (in-line) e o IPS (ou o Firewall).

- **8. WAF atua na Camada de Aplicacao:**

Diferente de firewalls de pacotes comuns, o WAF analisa dados de HTTP/HTTPS da camada de aplicacao (camada 7 do modelo OSI) para bloquear injecoes de SQL Injection.

- **9. Certificacao corporativa e da ISO 27001:**

Uma empresa so pode se certificar oficialmente na norma ISO 27001 (requisitos do SGSI). A norma ISO 27002 e apenas um guia de boas praticas complementar.

- **10. Criptografia nao impede deletar dados:**

A criptografia garante a Confidencialidade da informacao. Ela nao protege contra a exclusao acidental ou intencional de arquivos (risco a Disponibilidade), que exige politicas de backup.

FICHA DE REVISAO GERAL

Foque os estudos finais nos fluxos de criptografia assimetrica (quem cifra com qual chave), definicoes de malwares (Virus vs. Worm vs. Ransomware), diferencas de backup (Incremental vs Diferencial) e o escopo das normas ISO 27001 e 27002.